

Mise en place d'un VPN client to Site avec PfSense



OpenVPN

Préparé par:

Léo Gauthier

Le 27/04/2024

Partie 1

Partie 2

Partie 3

Partie 4

Partie 5

Partie 6

Conclusion 18



Prérequis

Avant de commencer à suivre cette documentation sur la mise en place d'un **VPN client to site**, il est important de s'assurer que vous disposez des prérequis suivants :

- **Infrastructure matérielle :**

Un pare-feu PfSense installé sur du matériel compatible ou dans une machine virtuelle

Accès administratif à PfSense pour effectuer les configurations nécessaires.

Une machine extérieure au réseau du routeur PfSense

- **Configuration réseau :**

Une connexion Internet fonctionnelle sur le site où PfSense est déployé.

Une adresse IP publique statique ou un nom de domaine résolu pour le pare-feu PfSense, pour permettre aux clients VPN de se connecter.

Une planification des adresses IP à utiliser pour les clients VPN, qui peut inclure la configuration d'un pool d'adresses IP sur le serveur OpenVPN.

INTRODUCTION

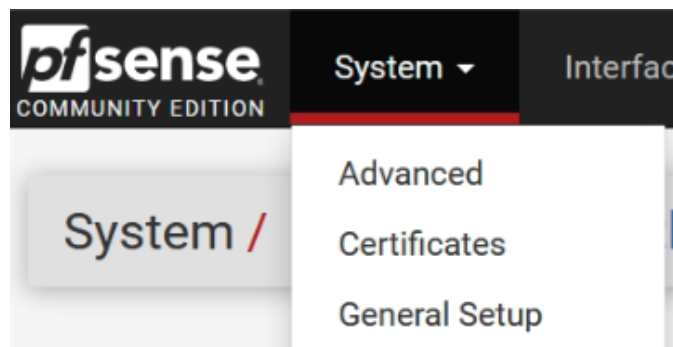
Cette documentation vise à guider les administrateurs système dans la configuration d'un **VPN client-to-site** avec **PfSense** et **OpenVPN**. Elle offre un aperçu des étapes nécessaires pour permettre aux utilisateurs distants de se connecter de manière sécurisée au réseau interne de l'organisation.

À travers cette documentation, nous explorerons la configuration de **PfSense** en tant que serveur **VPN** et l'installation d'**OpenVPN** pour faciliter cette connexion sécurisée. En mettant l'accent sur les bonnes pratiques de sécurité, cette documentation fournira des instructions détaillées pour établir un **environnement VPN robuste et fiable, adapté aux besoins de votre organisation**.

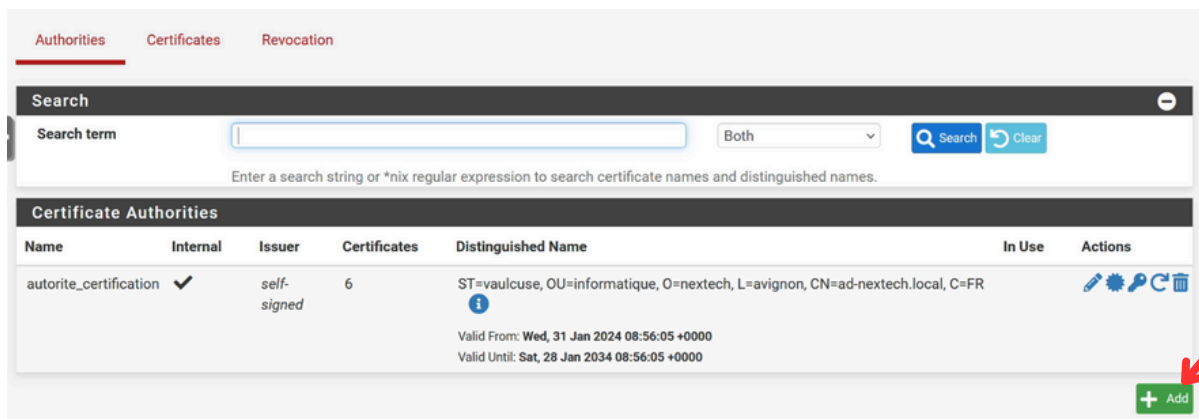
PARTIE 1

Création de l'autorité de certification

Une fois sur notre pfsense, aller dans System puis Certificates :



Dans Authorities, cliquer sur **Add**



On peut compléter comme l'exemple :

Create / Edit CA

Descriptive name

Autorité de certification

The name of this entry as displayed in the GUI for reference.
This name can contain spaces but it cannot contain any of the following characters: ?, >, <, &, /, \, " , '

Method

Create an internal Certificate Authority

Trust Store

☐ Add this Certificate Authority to the Operating System Trust Store

When enabled, the contents of the CA will be added to the trust store so that they will be trusted by the operating system.

Randomize Serial

☐ Use random serial numbers when signing certificates

When enabled, if this CA is capable of signing certificates then serial numbers for certificates signed by this CA will be automatically randomized and checked for uniqueness instead of using the sequential value from Next Certificate Serial.

Internal Certificate Authority

Key type

RSA

2048

The length to use when generating a new RSA key, in bits.
The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.

Digest Algorithm

sha256

The digest method used when the CA is signed.
The best practice is to use SHA256 or higher. Some services and platforms, such as the GUI web server and OpenVPN, consider weaker digest algorithms invalid.

Lifetime (days)

3650

Common Name

internal-ca

The following certificate authority subject components are optional and may be left blank.

Country Code

None

State or Province

France

City

Avignon

Organization

NEXTECH

Organizational Unit

e.g. My Department Name (optional)

Maintenant on va dans l'onglet **Certificates** :

CA'sCertificatesCertificate Revocation

Certificates

Name	Issuer	Distinguished Name	In Use	Actions
webConfigurator default (5cf00801c94a4) Server Certificate CA: No Server: Yes	self-signed	O=pfSense webConfigurator Self-Signed Certificate, CN=pfSense-5cf00801c94a4 Valid From: Thu, 30 May 2019 16:42:41 +0000 Valid Until: Tue, 19 Nov 2024 16:42:41 +0000	webConfigurator	

+ Add/Sign

On clique sur **Add**

On clique sur **Add**

On nomme le certificat et on ajoute le common name et on change le type de certificat pour un certificat Serveur :

The screenshot shows the 'Certificate Attributes' tab in the Active Directory Certificate Services console. The 'Common Name' field is set to 'ad-nextech-firewall'. Below this, a message states: 'The following certificate subject components are optional and may be left blank.' The fields for 'Country Code' (FR), 'State or Province' (vaulcuse), 'City' (avignon), 'Organization' (nextech), and 'Organizational Unit' (informatique) are filled in. The 'Certificate Type' is set to 'Server Certificate'. The 'Alternative Names' section shows a dropdown for 'FQDN or Hostname' and a text box for the value. A 'Save' button is at the bottom left, and the 'Active Directory' logo is at the bottom right.

Common Name	ad-nextech-firewall
The following certificate subject components are optional and may be left blank.	
Country Code	FR
State or Province	vaulcuse
City	avignon
Organization	nextech
Organizational Unit	informatique

Certificate Attributes

Attribute Notes The following attributes are added to certificates and requests when they are created or signed. These attributes behave differently depending on the selected mode.
For Internal Certificates, these attributes are added directly to the certificate as shown.

Certificate Type Server Certificate
Add type-specific usage attributes to the signed certificate. Used for placing usage restrictions on, or granting abilities to, the signed certificate.

Alternative Names FQDN or Hostname
Type Value
Enter additional identifiers for the certificate in this list. The Common Name field is automatically added to the certificate as an Alternative Name. The signing CA may ignore or change these values.

Add SAN Row + Add SAN Row

Save

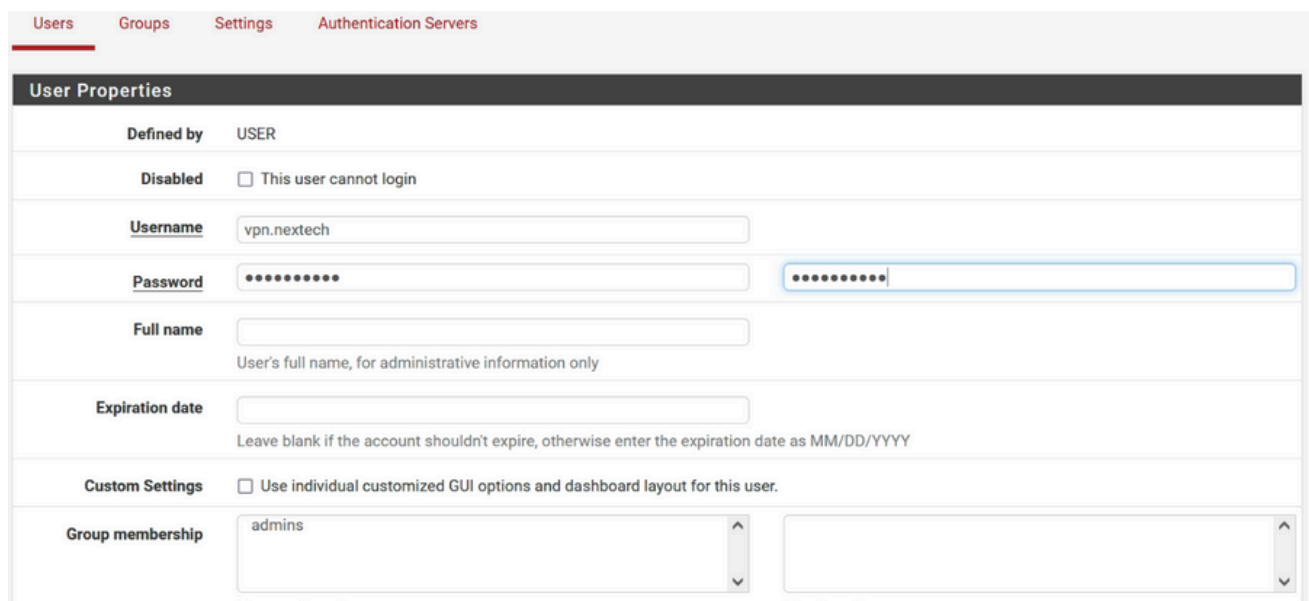
On enregistre.

La partie certificat est terminée.

PARTIE 2

Création utilisateur PfSense

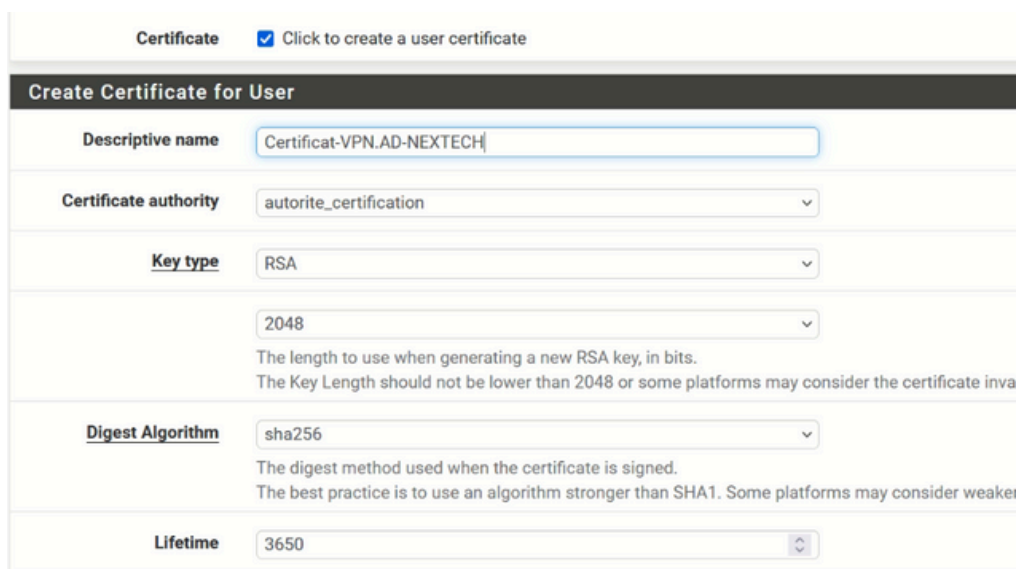
Dans **System** puis **User Manager**:



The screenshot shows the 'User Properties' form in the PfSense User Manager interface. The 'Users' tab is selected. The form includes fields for 'Defined by' (set to USER), 'Disabled' (checkbox), 'Username' (set to vpn.nextech), 'Password' (two masked input fields), 'Full name' (with a description: 'User's full name, for administrative information only'), 'Expiration date' (with a description: 'Leave blank if the account shouldn't expire, otherwise enter the expiration date as MM/DD/YYYY'), 'Custom Settings' (checkbox), and 'Group membership' (a dropdown menu showing 'admins').

On donne un nom d'utilisateur puis on lui attribue un mot de passe.

On coche la case, Click to create a user certificate



The screenshot shows the 'Create Certificate for User' form. At the top, the 'Certificate' checkbox is checked with the label 'Click to create a user certificate'. The form fields include: 'Descriptive name' (set to Certificat-VPN.AD-NEXTECH), 'Certificate authority' (set to autorite_certification), 'Key type' (set to RSA), 'Key length' (set to 2048, with a description: 'The length to use when generating a new RSA key, in bits. The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid'), 'Digest Algorithm' (set to sha256, with a description: 'The digest method used when the certificate is signed. The best practice is to use an algorithm stronger than SHA1. Some platforms may consider weaker algorithms'), and 'Lifetime' (set to 3650).

On enregistre avec **Save**

PARTIE 3

Configuration OpenVPN

Dans **VPN** puis **OpenVPN** on clique sur **Add**:

The screenshot shows the OpenVPN configuration interface with the following sections:

- General Information**
 - Description:** Accès distant OpenVPN (A description of this VPN for administrative reference.)
 - Disabled:** ☐ Disable this server (Set this option to disable this server without removing it from the list.)
 - Unique VPN ID:** Server 1 (ovpns1)
- Mode Configuration**
 - Server mode:** Remote Access (SSL/TLS + User Auth)
 - Backend for authentication:** Active Directory, Local Database (selected)
 - Device mode:** tun - Layer 3 Tunnel Mode (tun mode carries IPv4 and IPv6 (OSI layer 3) and is the most common and compatible mode across all platforms. tap mode is capable of carrying 802.3 (OSI Layer 2).)

Il est conseillé de changer le port OpenVPN pour plus de sécurité

The screenshot shows the OpenVPN configuration interface with the following sections:

- Endpoint Configuration**
 - Protocol:** UDP on IPv4 only
 - Interface:** WAN (The interface or Virtual IP address where OpenVPN will receive client connections.)
 - Local port:** 772 (The port used by OpenVPN to receive client connections.)
- Cryptographic Settings**
 - TLS Configuration:** ☒ Use a TLS Key (A TLS key enhances security of an OpenVPN connection by requiring both parties to have a common key before a peer can perform a TLS handshake. This layer of HMAC authentication allows control channel packets without the proper key to be dropped, protecting the peers from attack or unauthorized connections. The TLS Key does not have any effect on tunnel data.)
 - TLS Key:** # 2048 bit OpenVPN static key # -----BEGIN OpenVPN Static key V1----- f57ff367ebd6fc6019484da092ce052d 2625cbc58e524be3ecbd06528c93b4b4 (Paste the TLS key here. This key is used to sign control channel packets with an HMAC signature for authentication when establishing the tunnel.)
 - TLS Key Usage Mode:** TLS Authentication (In Authentication mode the TLS key is used only as HMAC authentication for the control channel, protecting the peers from unauthorized connections. Encryption and Authentication mode also encrypts control channel communication, providing more privacy and traffic control channel obfuscation.)

On sélectionne le certificat OpenVPN que nous avons crée juste avant:

TLS keydir direction	Use default direction
The TLS Key Direction must be set to complementary values on the client and server. For example, if the server is set to 0, the client must be set to 1. Both may be set to omit the direction, in which case the TLS Key will be used bidirectionally.	
Peer Certificate Authority	autorite_certification
Peer Certificate Revocation list	No Certificate Revocation Lists defined. One may be created here: System > Cert. Manager
OCSP Check	☐ Check client certificates with OCSP
Server certificate	Certificat-OpenVPN (Server: Yes, CA: autorite_certification, In Use) Certificates known to be incompatible with use for OpenVPN are not included in this list, such as certificates using incompatible ECDSA curves or weak digest algorithms.
DH Parameter Length	2048 bit Diffie-Hellman (DH) parameter set used for key exchange.
ECDH Curve	Use Default The Elliptic Curve to use for key exchange. The curve from the server certificate is used by default when the server uses an ECDSA certificate. Otherwise, secp384r1 is used as a fallback.

Fallback Data Encryption Algorithm	AES-256-CBC (256 bit key, 128 bit block) The Fallback Data Encryption Algorithm used for data channel packets when communicating with clients that do not support data encryption algorithm negotiation (e.g. Shared Key). This algorithm is automatically included in the Data Encryption Algorithms list.
Auth digest algorithm	SHA256 (256-bit) The algorithm used to authenticate data channel packets, and control channel packets if a TLS Key is present. When an AEAD Encryption Algorithm mode is used, such as AES-GCM, this digest is used for the control channel only, not the data channel. The server and all clients must have the same setting. While SHA1 is the default for OpenVPN, this algorithm is insecure.
Hardware Crypto	No Hardware Crypto Acceleration
Certificate Depth	One (Client+Server) When a certificate-based client logs in, do not accept certificates below this depth. Useful for denying certificates made with intermediate CAs generated from the same CA as the server.
Strict User-CN Matching	☐ Enforce match When authenticating users, enforce a match between the common name of the client certificate and the username given at login.
Client Certificate Key Usage Validation	☐ Enforce key usage Verify that only hosts with a client certificate can connect (EKU: "TLS Web Client Authentication").

Tunnel Settings

IPv4 Tunnel Network	192.168.10.0/24 This is the IPv4 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. 10.0.8.0/24). The first usable address in the network will be assigned to the server virtual interface. The remaining usable addresses will be assigned to connecting clients. A tunnel network of /30 or smaller puts OpenVPN into a special peer-to-peer mode which cannot push settings to clients. This mode is not compatible with several options, including Exit Notify, and Inactive.
IPv6 Tunnel Network	This is the IPv6 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. fe80::/64). The ::1 address in the network will be assigned to the server virtual interface. The remaining addresses will be assigned to connecting clients.
Redirect IPv4 Gateway	☐ Force all client-generated IPv4 traffic through the tunnel.
Redirect IPv6 Gateway	☐ Force all client-generated IPv6 traffic through the tunnel.
IPv4 Local network(s)	10.10.0.0/16 IPv4 networks that will be accessible from the remote endpoint. Expressed as a comma-separated list of one or more CIDR ranges or host/network type aliases. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.

Client Settings	
Dynamic IP	☒ Allow connected clients to retain their connections if their IP address changes.
Topology	net30 -- Isolated /30 network per client Specifies the method used to supply a virtual adapter IP address to clients when using TUN mode on IPv4. Some clients may require this be set to "subnet" even for IPv6, such as OpenVPN Connect (iOS/Android). Older versions of OpenVPN (before 2.0.9) or clients such as Yealink phones may require "net30".

Advanced Client Settings	
DNS Default Domain	☒ Provide a default domain name to clients
DNS Default Domain	AD-NEXTECH.local
DNS Server enable	☒ Provide a DNS server list to clients. Addresses may be IPv4 or IPv6.
DNS Server 1	10.10.10.150
DNS Server 2	10.20.100.155

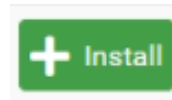
Pour le reste on laisse par défaut.

PARTIE 4

Exporter la configuration

Dans **System** puis **Package Manager** on clique sur **Available Packages** :

On cherche **openvpn-client-export** et on clique sur
puis **Confirm**.



Maintenant on va dans **VPN** puis **OpenVPN** dans **Client Export**

On clique sur **Save as default**

Maintenant en bas de la page dans OpenVPN Clients on télécharge les fichiers suivants :

PARTIE 5

Création d'une règle pare-feu

Dans **Firewall** puis **Rules** on clique sur **Wan** :

Floating **WAN** LAN AVG_LAN_VLANS VLAN20 VLAN10 DMZ VLAN30 IPsec OpenVPN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✗ 0/258.71 MiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogus networks	⚙️
☐	✓ 1/200 KiB	IPv4 UDP	*	*	WAN address	772	*	none		Accès distant OpenVPN	📌 ✎ 🗑️ ⛔
☐	✓ 0/2 KiB	IPv4 TCP	*	*	WAN address	80 (HTTP)	*	none			📌 ✎ 🗑️ ⛔

⬆️ Add ⬇️ Add 🗑️ Delete ⛔ Toggle 📄 Copy 💾 Save ➕ Separator

Action Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface WAN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol UDP
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match Any Source Address /

⚙️ Display Advanced

The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match WAN address Destination Address /

Destination Port Range (other) 772 (other) 772
From Custom To Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log ☐ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the [Status: System Logs: Settings](#) page).

Description Accès distant OpenVPN
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

On clique sur **Save**

Maintenant dans OpenVPN, on va déclarer les règle pour accéder aux ressources :

Un exemple pour accéder au protocole RDP (Bureau à distance).

Floating

WAN

LAN

AVG_LAN_VLANS

VLAN20

VLAN10

DMZ

VLAN30

IPsec

OpenVPN

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 2/63 KiB	IPv4 *	*	*	*	*	*	none			
☐	✓ 0/0 B	IPv4 TCP	*	*	10.10.10.0/24	3389 (MS RDP)	*	none		Autoriser RDP	

↑

Add

↓

Add

Delete

Toggle

Copy

Save

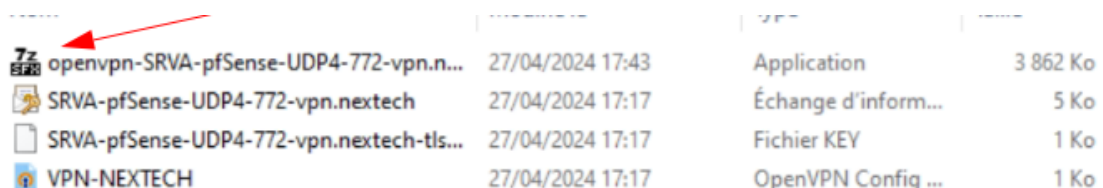
Separator

PARTIE 6

Test du bon fonctionnement

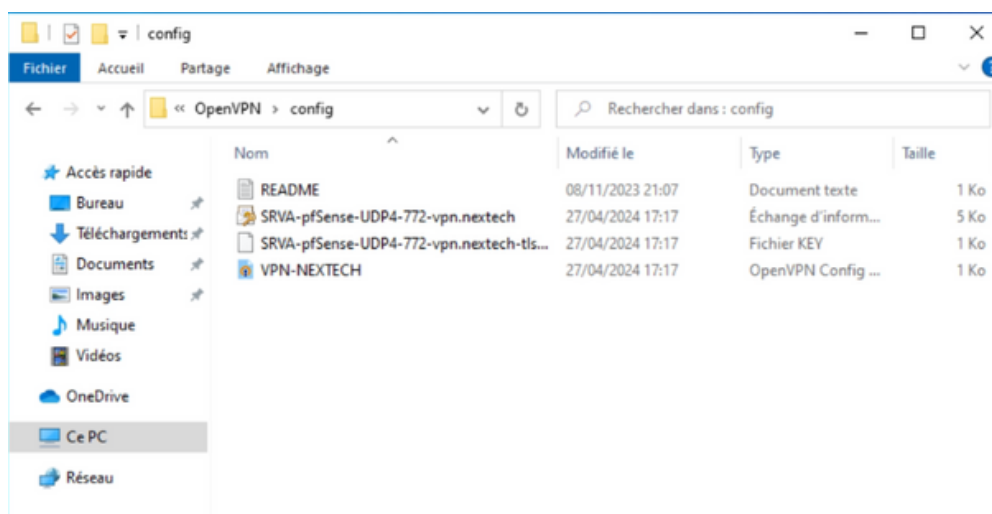
Sur un ordinateur distant, on récupère les fichiers de configuration et d'installation que nous avons téléchargé.

On installe OpenVPN sur la machine :

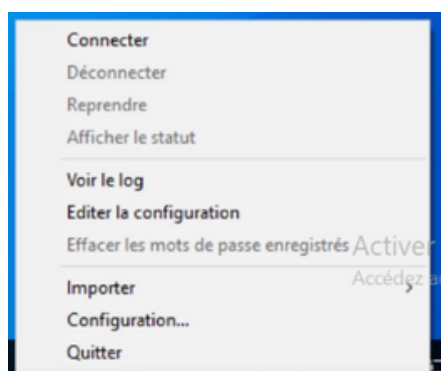


7z	openvpn-SRVA-pfSense-UDP4-772-vpn.n...	27/04/2024 17:43	Application	3 862 Ko
📄	SRVA-pfSense-UDP4-772-vpn.nextech	27/04/2024 17:17	Échange d'inform...	5 Ko
📄	SRVA-pfSense-UDP4-772-vpn.nextech-tls...	27/04/2024 17:17	Fichier KEY	1 Ko
📄	VPN-NEXTECH	27/04/2024 17:17	OpenVPN Config ...	1 Ko

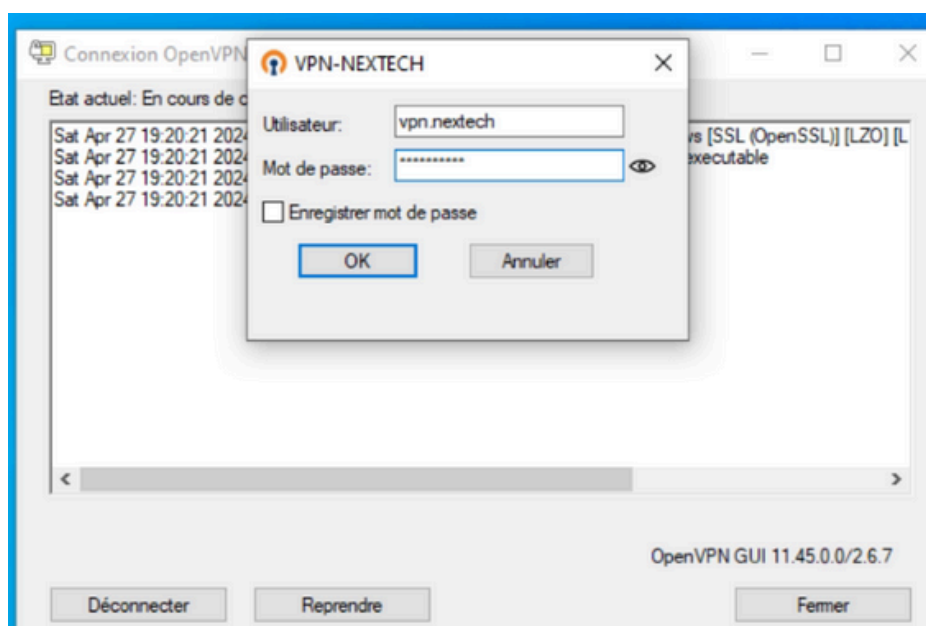
Puis on ajoute les trois autres fichiers dans la configuration de OpenVPN, dans le chemin suivant : C:\Program Files\OpenVPN\config



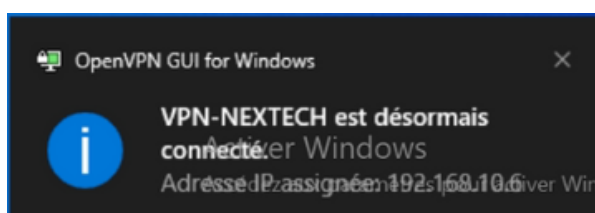
Maintenant on fait click droit sur l'icône en bas à droite puis **connecter**



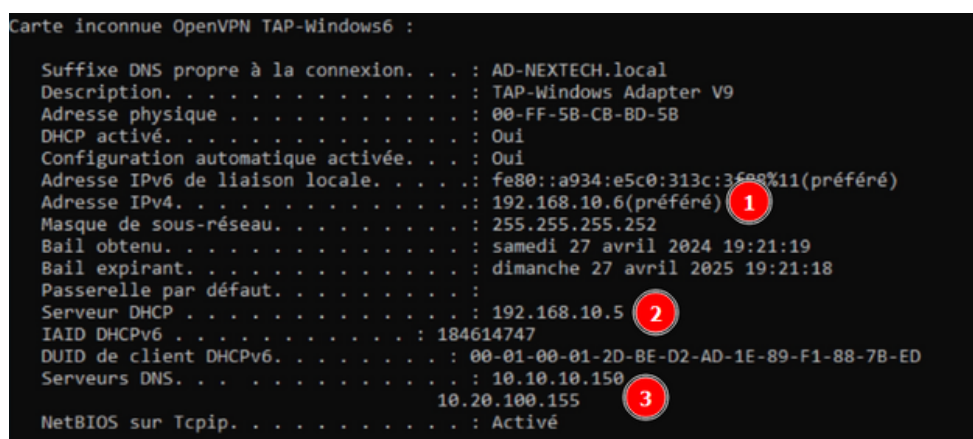
On entre ensuite les informations du compte PfSense que nous avons crée pour le VPN:



On clique sur **OK**

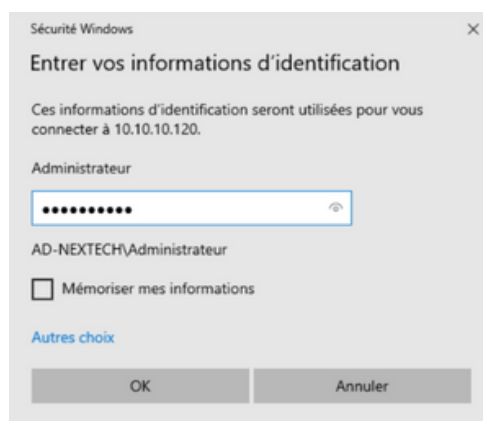
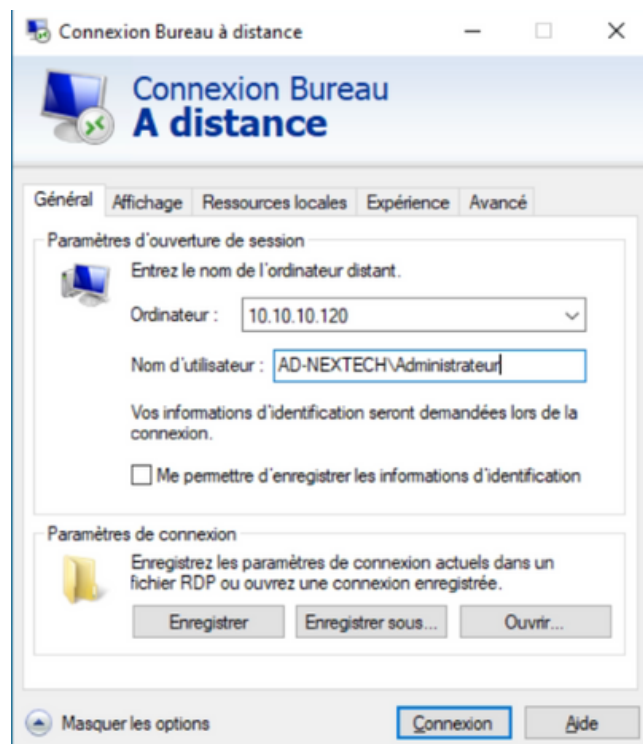


On est bien connecté.



On retrouve bien les bonnes informations que nous avons configuré.

Faisons le test en nous connectant sur notre serveur RDS :



La fenêtre d'authentification apparaît bien, nous sommes bien connectés et le VPN est bien configuré

CONCLUSION

La configuration d'un **VPN client-to-site avec PfSense et OpenVPN** offre une connectivité sécurisée pour les utilisateurs distants vers le réseau interne de l'organisation. En mettant en œuvre les bonnes pratiques de sécurité telles que l'utilisation de **certificats SSL/TLS** et la surveillance continue, vous pouvez renforcer la protection de votre réseau contre les menaces potentielles. Avec les connaissances acquises dans cette documentation, vous êtes désormais prêt à établir et à maintenir un **VPN client-to-site robuste, garantissant un accès sûr et fiable aux ressources réseau pour vos utilisateurs distants**.

Vous pouvez retrouver d'autres documentations sur la page [documentation](#) de mon portfolio.